BÁO CÁO TIẾN ĐỘ DỰ ÁN

Xây dựng & Triển khai Kiến trúc Bảo mật Zero Trust cho Hệ thống Y tế OpenEMR

52300268 - Nguyễn Hoàng Việt
52300267 - Huỳnh Nguyễn Quốc Việt

1. TỔNG QUAN TIẾN ĐỘ DỰ ÁN

Chỉ số theo dõi	Giá trị kế hoạch	Hiện trạng thực tế	Tỷ lệ hoàn thành
Tổng số công việc (Tasks)	32 tasks	18 tasks cốt lõi	**~55% - 60%**
Giai đoạn triển khai	5 giai đoạn	Đang hoàn tất Giai đoạn 3	Đúng lộ trình chung

2. NỘI DUNG ĐÃ THỰC HIỆN Ở LẦN BÁO CÁO TRƯỚC (GIAI ĐOẠN 1 & 2)

- **Quy hoạch kiến trúc mạng:** Khảo sát và phân tách độc lập các vùng mạng chuyên biệt bao gồm DMZ Zone, App Zone, DB Zone và Security Zone.
- **Chính sách phân quyền:** Xây dựng ma trận phân quyền Role-Permission Matrix v1 và chuẩn hóa các luồng nghiệp vụ y tế cốt lõi (từ BF-01 đến BF-05).
- **Hạ tầng ảo hóa:** Khởi tạo hạ tầng ảo hóa Proxmox VE, cấu hình mạng nội bộ và dựng các máy ảo (VM) độc lập cho từng dịch vụ.
- **Cài đặt dịch vụ nền tảng:** Triển khai riêng lẻ các thành phần chính bao gồm Keycloak (Identity Provider), Pomerium (ZTNA Gateway), OpenEMR (Ứng dụng quản lý y tế) và Wazuh Manager.

3. NỘI DUNG ĐÃ THỰC HIỆN TRONG GIAI ĐOẠN 3

- **Xác thực nâng cao:** Bật xác thực hai yếu tố (MFA/OTP) trên Keycloak bắt buộc đối với toàn bộ người dùng khi truy cập hệ thống.
- **Tên miền & HTTPS:** Cấu hình Pomerium kết nối HTTPS an toàn với chứng chỉ bảo mật và gán tên miền riêng cho hệ thống OpenEMR.
- **Tích hợp SSO:** Thiết lập liên thông OIDC giữa Pomerium và Keycloak, cho phép chuyển hướng xác thực tập trung (Single Sign-On).
- **Kiểm soát truy cập (ZTNA):** Định cấu hình các quy tắc truy cập (Pomerium Policy) dựa trên Vai trò/Thuộc tính (RBAC/ABAC), đảm bảo giới hạn quyền truy cập OpenEMR đúng đối tượng.
- **Phân quyền nghiệp vụ:** Mở rộng và đồng bộ cấu hình RBAC trên ứng dụng OpenEMR cho các nhóm vai trò: Bác sĩ, Y tá, Lễ tân và IT Admin.
- **Tách biệt dữ liệu:** Chuyển toàn bộ cơ sở dữ liệu (285 bảng) sang máy chủ MariaDB độc lập (VM104) và kết nối OpenEMR thành công.
- **Sao lưu dự phòng:** Thực hiện sao lưu đầy đủ (Full Backup) cơ sở dữ liệu OpenEMR để đảm bảo an toàn dữ liệu trước khi nâng cấp cấu hình bảo mật sâu.
- **Xây dựng bộ Test Case chuẩn hóa:** Đã hoàn thiện bộ Test Case toàn diện gồm **61 Test Cases** (được lưu trữ tại tệp 🗋 File ZeroTrust_TestCases_v2.xlsx), bao phủ đầy đủ 8 giai đoạn kiểm thử kiến trúc Zero Trust.
- **Tình trạng thực thi kiểm thử:** Theo dõi trực tiếp qua Checklist (tệp 🗋 File Checklist_Hoan_Thanh_Zero_Trust.xlsx), dự án đã hoàn thành **23/40 mục tiêu** hạ tầng & nghiệp vụ (đạt tỉ lệ **~57.5%**). Hiện tại đang tiếp tục triển khai 17 mục tiêu còn lại.

4. KHÓ KHĂN & VẤN ĐỀ ĐANG GẶP PHẢI

- **Mã hóa dữ liệu lưu trữ (MariaDB TDE):** Đã khởi tạo file khóa và passphrase nhưng chưa kích hoạt/xác nhận thành công tính năng mã hóa dữ liệu thực tế trên các bảng dữ liệu của MariaDB.
- **Tích hợp cụm Wazuh SIEM v4.14.7:** File Docker Compose ban đầu thiếu thành phần Wazuh Indexer (OpenSearch), dẫn đến Wazuh Dashboard chưa truy xuất và hiển thị được biểu đồ log trực quan từ Pomerium và Keycloak.

5. HƯỚNG PHÁT TRIỂN VÀ KẾ HOẠCH TIẾP THEO (GIAI ĐOẠN 4 & 5)

- **Bảo mật cơ sở dữ liệu & Hạ tầng:** Hoàn thiện cấu hình mã hóa MariaDB TDE và kích hoạt Proxmox Firewall nhằm ngăn chặn hoàn toàn các kết nối bypass Gateway.
- **Hoàn thiện SIEM:** Bổ sung Wazuh Indexer v4.14.7, tự động sinh chứng chỉ SSL nội bộ cho toàn bộ cụm Wazuh (Indexer – Manager – Dashboard).
- **Giám sát thời gian thực:** Tập trung thu thập và phân tích log truy cập/xác thực theo thời gian thực từ Keycloak và Pomerium đẩy về Wazuh SIEM Dashboard.
- **Kiểm thử bảo mật:** Tiến hành chạy toàn bộ 20 Test Cases bảo mật (TC-01 đến TC-20), giả lập các kịch bản tấn công và truy cập trái phép để kiểm chứng kiến trúc.
- **Đóng gói sản phẩm:** Đóng gói toàn bộ mã nguồn cấu hình dạng Infrastructure as Code (IaC) chuẩn One-Click Docker Compose vào thư mục source_code/Source/ kèm hướng dẫn readme.txt chi tiết phục vụ công tác nộp bài và đánh giá.